

EPICODE — Institute of Technology

Malware Analysis & IOC

Analisi Ransomware con FlareVM, VirusTotal e Identificazione Indicatori di Compromissione

Configurazione laboratorio FlareVM, analisi di CryptoLocker, WannaCry e Locky.AZ tramite VirusTotal, identificazione IOC di rete e persistenza, mapping MITRE ATT&CK e validazione con LLM

Studente	Mauro Picca
Data	1 Giugno 2026
Corso	EPICODE — Cybersecurity & Ethical Hacking
Modulo	S9 L1 — Malware Analysis e Identificazione IOC
Ambiente	FlareVM + Kali Linux (VirtualBox) — Rete isolata 192.168.50.0/24

Attività svolta esclusivamente a fini didattici in ambiente di laboratorio controllato

Cybersecurity & Ethical Hacking | EPICODE

Indice

1. Configurazione del Laboratorio	3
2. Avvio del Repository Malware	4
3. Selezione dei Campioni	5
4. Simulazione della Persistenza	5
5. Analisi VirusTotal	7
6. Tabella IOC	8
7. Analisi dei Malware	8
8. Analisi tramite LLM	10
9. Conclusioni	11

1. Configurazione del Laboratorio

È stato predisposto un ambiente di analisi isolato composto da due macchine virtuali, configurate su una rete interna separata dalla rete fisica per garantire che l'eventuale esecuzione di malware non possa raggiungere sistemi esterni.

Sistema	Indirizzo IP	Ruolo
Kali Linux	192.168.50.100	Gateway/Router — isolamento rete
FlareVM	192.168.50.150	Workstation analisi malware

Prima di iniziare le attività è stato creato uno snapshot denominato Clean_FlareVM_MalwareLab per consentire il ripristino rapido della macchina virtuale in caso di compromissione accidentale durante l'analisi.

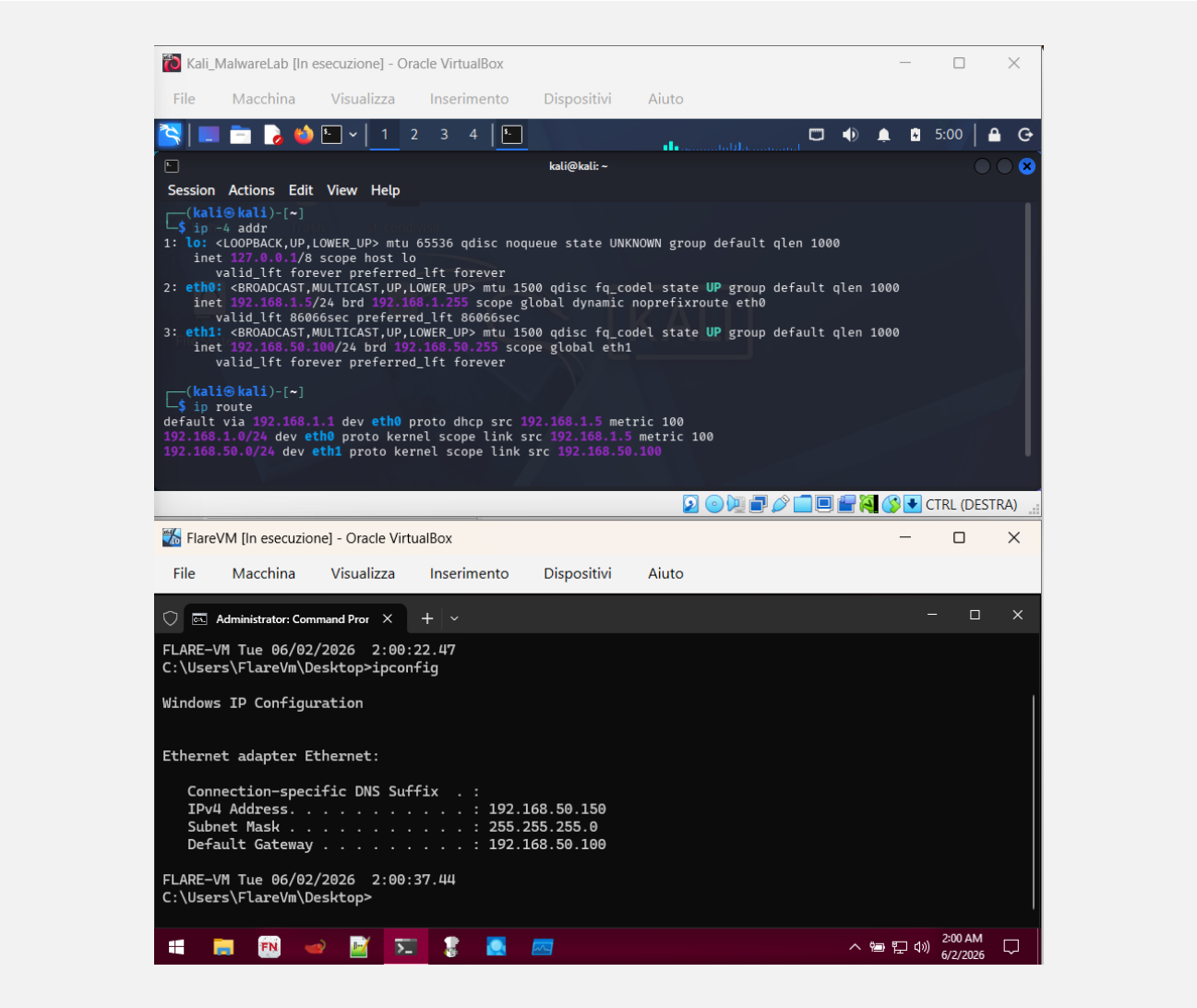


Figura 1 – Configurazione del laboratorio: FlareVM e Kali Linux su rete isolata con snapshot Clean_FlareVM_MalwareLab.

💡 FlareVM è una distribuzione Windows-based sviluppata da Mandiant/FireEye appositamente per il malware analysis. Include strumenti come IDA Free, x64dbg, Ghidra, pestudio, Process Monitor, Wireshark e molti altri pre-installati e configurati per l'analisi statica e dinamica.

2. Avvio del Repository Malware

È stato eseguito lo script `malwareRepo.ps1` presente sul Desktop della FlareVM. Lo script ha scaricato e organizzato una raccolta di campioni malware suddivisi per categoria:

- Banking Malware
- Botnets
- RAT (Remote Access Trojan)
- Trojan
- Virus
- Worm
- Ransomware

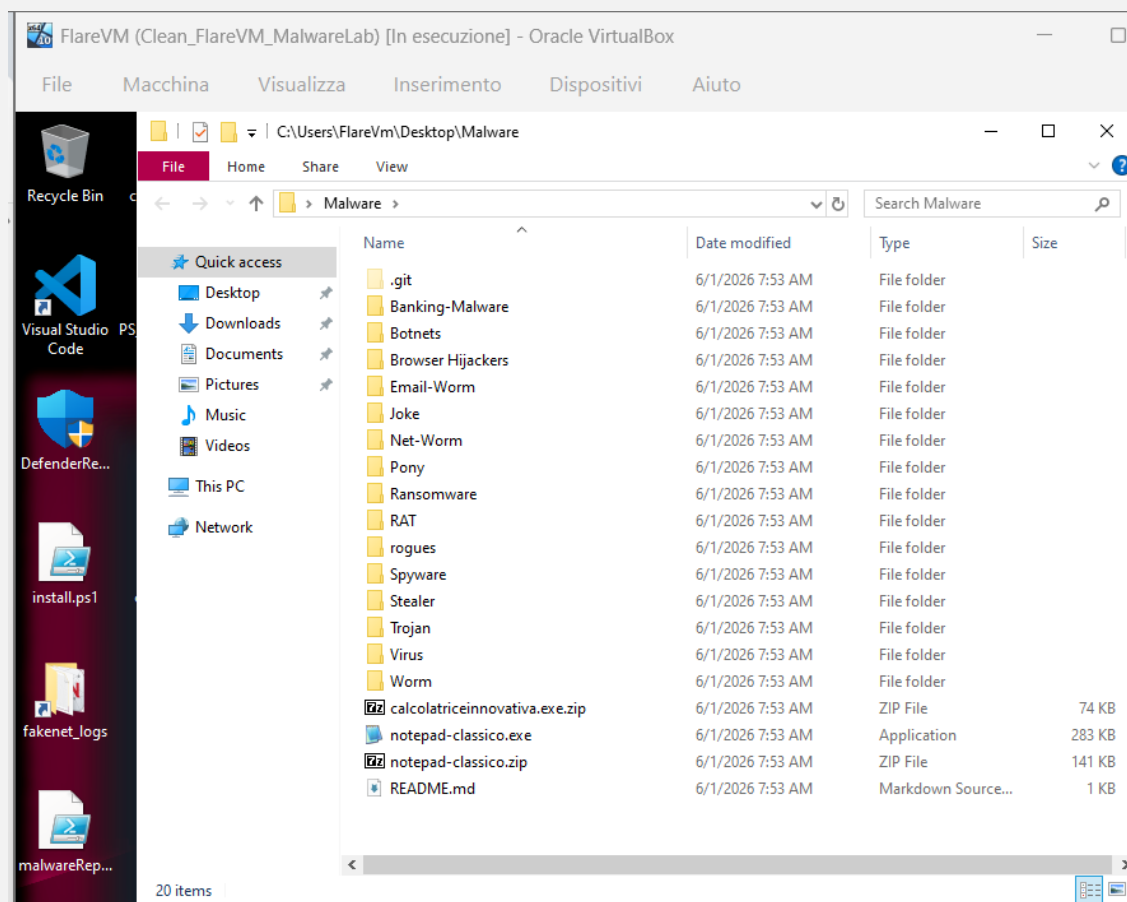


Figura 2 – Repository malware disponibile sulla FlareVM dopo l'esecuzione di `malwareRepo.ps1`.

3. Selezione dei Campioni

Dalla categoria Ransomware sono stati selezionati tre campioni per l'analisi. Per ciascuno è stato calcolato l'hash SHA256 tramite gli strumenti disponibili in FlareVM, necessario per la ricerca su VirusTotal.

Campione	Tipo	Note
CryptoLocker.exe	EXE — Ransomware (famiglia Crilock)	Hash SHA256: d765e722e295969c0a5c2d90f549db8b89ab6179
WannaCry.exe	EXE — Ransomware (WannaCryptor)	Hash SHA256: be22645c61949ad6a077373a7d6cd85e3fae4431
Locky.AZ.exe	DLL — Ransomware (Locky/encoder)	Hash SHA256: 2e4319ff62c03a539b2b2f71768a0cfc0adcaedb — distribuita come .exe ma è una DLL eseguita tramite rundll32

Si segnala che il campione Locky.AZ, pur essendo distribuito come file .exe nel repository, su VirusTotal corrisponde in realtà a una DLL (Alert.dll) eseguita tramite rundll32 (export DllMain / #1) e non a un eseguibile standalone.

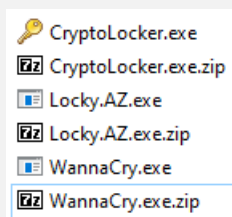


Figura 3 – I tre campioni ransomware selezionati con i relativi hash SHA256.

4. Simulazione della Persistenza

Per comprendere una delle tecniche più comuni utilizzate dai malware per sopravvivere al riavvio del sistema, è stata simulata la creazione di una chiave di persistenza nel Registro di Windows. Questa tecnica è classificata come MITRE ATT&CK T1547.001 (Boot or Logon Autostart Execution: Registry Run Keys).

La chiave Run nel Registro di Windows è uno dei meccanismi di persistenza più semplici e diffusi: qualsiasi valore inserito in questo percorso viene eseguito automaticamente ad ogni avvio della sessione utente.

```
Percorso: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Run
Nome:      TestPersistence
Dati:      notepad.exe
```

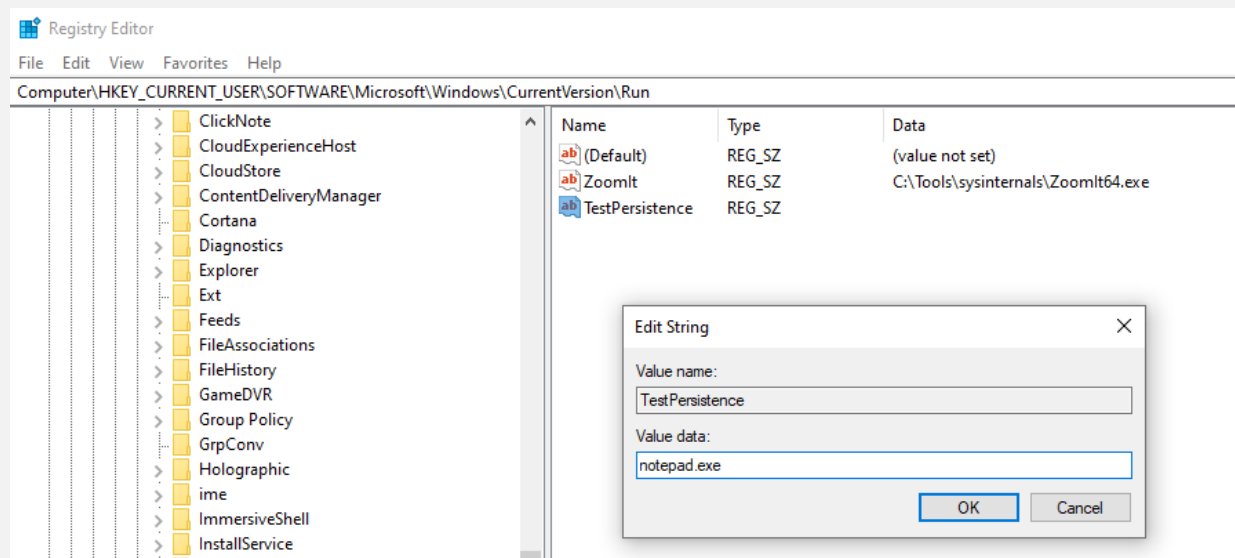


Figura 4 – Creazione della chiave di persistenza TestPersistence in HKCU\...\Run.

Dopo il riavvio della macchina virtuale, il programma Notepad è stato avviato automaticamente all'avvio della sessione utente, dimostrando il corretto funzionamento della persistenza tramite chiave Run. La chiave è stata successivamente rimossa per riportare il sistema allo stato originale.

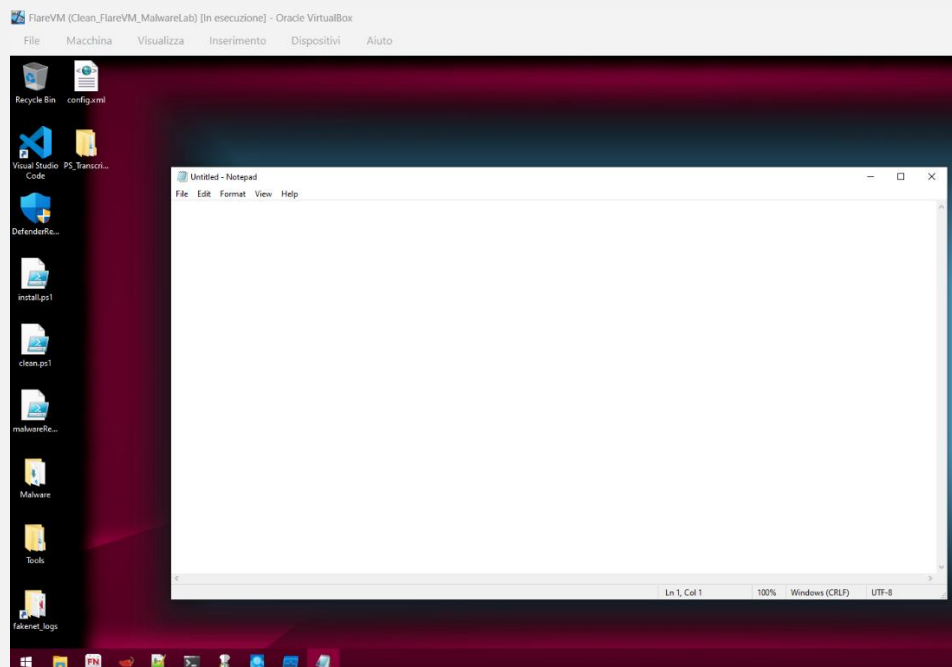


Figura 5 – Verifica della persistenza: Notepad avviato automaticamente dopo il riavvio della VM.

🔍 In un malware reale la chiave Run punta a un eseguibile malevolo invece di notepad.exe. CryptoLocker e WannaCry usano esattamente questa tecnica per garantire la propria esecuzione ad ogni riavvio del sistema infetto.

5. Analisi VirusTotal

Gli hash SHA256 dei tre campioni sono stati ricercati su VirusTotal. Per ciascun campione sono stati analizzati tre tab principali:

Detection — numero di motori antivirus che rilevano il file come malevolo e la famiglia malware identificata

Relations — domini, IP e URL con cui il malware ha comunicato in ambienti sandbox

Behavior — azioni eseguite dal malware: chiavi di registro modificate, file creati/eliminati, processi avviati, regole Sigma attivate

L'analisi del tab Relations è stata fondamentale per distinguere gli IOC reali dal traffico benigno: diversi domini Microsoft e Bing rilevati inizialmente come IOC si sono rivelati telemetria di sistema e controlli di revoca certificati, non indicatori malevoli.

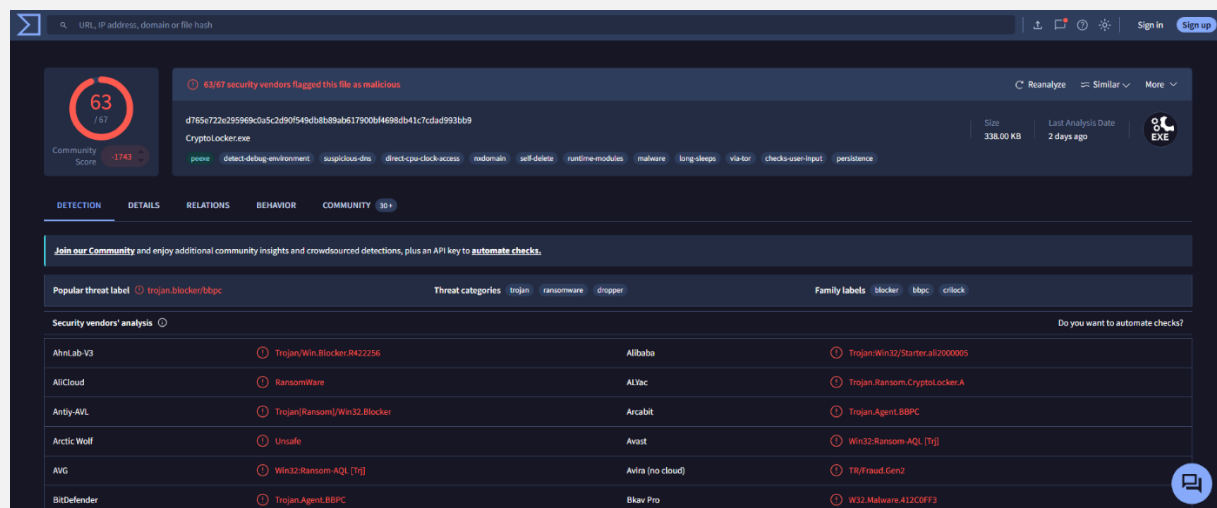


Figura 6 – Analisi VirusTotal di CryptoLocker: detection ratio, famiglie e tab Relations/Behavior.

⚠️ I domini api.msn.com, a-0003.dc-msedge.net e tse1.mm.bing.net, inizialmente identificati come IOC, sono stati esclusi dalla tabella in quanto traffico benigno di telemetria Windows e controllo certificati — non indicatori malevoli.

6. Tabella IOC

La tabella seguente riassume gli Indicatori di Compromissione (IOC) identificati per ciascun campione analizzato, dopo la verifica manuale e la rimozione del rumore benigno.

Campione	Hash SHA256 (parziale)	Detection	IOC di Rete (C2)	Persistenza
CryptoLocker (Crilock) — EXE	d765e722...993bb9	63/67	Domini DGA (aodxsfeulwsk.org, giooepvtqcnbx.net, hupmuhannyhqp.biz) POST HTTP /home/ IP C2: 184.164.136.134	HKCU\...\Run\CryptoLocker
WannaCry (WannaCryptor) — EXE	be22645c...684466	66/71	sqjolphimrr7jqw6.onion (Tor hidden service) URL pagamento Bitcoin	HKLM\...\Run\Microsoft Update Task Scheduler"
Locky.AZ (Locky/encoder) — DLL	2e4319ff...caedb6	65/71	Nessun C2 reale osservato (tse1.mm.bing.net = rumore benigno) Packer UPX (upx.sf.net)	Scheduled task in TaskCache (nessuna Run key chiara)

✎ Nota: la chiave di persistenza TestPersistence in HKCU\Software\Microsoft\Windows\CurrentVersion\Run\TestPersistence è stata creata durante la simulazione didattica (sezione 4) e non appartiene ad alcuno dei campioni analizzati.

7. Analisi dei Malware

7.1 CryptoLocker

CryptoLocker (famiglia Crilock) è un ransomware progettato per cifrare i file della vittima e richiedere un riscatto per il recupero dei dati. L'analisi su VirusTotal ha evidenziato:

- crittografia di tipo AES e RSA per la cifratura dei file
- C2 basato su algoritmo DGA (Domain Generation Algorithm) con richieste HTTP POST verso /home/ su numerosi domini generati dinamicamente — una regola IDS riconduce il traffico alla famiglia Zeus GameOver
- persistenza tramite chiave Run (HKCU\...\Run\CryptoLocker)
- tecniche di evasione: anti-debug, anti-sandbox/VM, long-sleeps, self-delete e comunicazione via Tor
- elevato tasso di rilevamento: 63/67 motori antivirus

Tecnica MITRE ATT&CK	ID	Descrizione
Registry Run Keys / Startup Folder	T1547.001	Persistenza tramite chiave Run nel Registro
Modify Registry	T1112	Modifica del Registro di Windows
Process Injection	T1055	Iniezione di codice in altri processi
Obfuscated Files or Information	T1027	Offuscamento del codice/payload
Virtualization/Sandbox Evasion	T1497	Rilevamento e bypass di sandbox/VM
Application Layer Protocol	T1071	C2 via HTTP/HTTPS
Data Encrypted for Impact	T1485	Cifratura file per impatto (ransomware)

7.2 WannaCry

WannaCry (famiglia WannaCryptor) è uno dei ransomware più noti della storia recente, distribuito su scala globale nel maggio 2017 sfruttando la vulnerabilità EternalBlue (MS17-010). L'analisi ha evidenziato:

- rilevamento da 66 motori antivirus su 71
- cifratura dei file con estensione .WCRY/.WCRYT e rilascio della nota di riscatto !Please Read Me!.txt insieme al componente !WannaDecryptor!.exe
- inibizione del ripristino tramite cancellazione delle shadow copy: vssadmin delete shadows /all /quiet, wmic shadowcopy delete, bcdedit ... recoveryenabled no, wbadmin delete catalog
- terminazione di servizi database e mail per permettere la cifratura: taskkill /f /im sqlserver.exe, sqlwriter.exe, MExchange*
- persistenza tramite chiave Run mascherata come aggiornamento Windows: "Microsoft Update Task Scheduler"
- C2 verso hidden service Tor (sqjolphimrr7jqw6.onion) e pagamento Bitcoin
- regole Sigma di livello CRITICAL: "WannaCry Ransomware Activity" e cancellazione shadow copy

Tecnica MITRE ATT&CK	ID	Descrizione
Data Encrypted for Impact	T1486	Cifratura massiva file (ransomware)
Inhibit System Recovery	T1490	Cancellazione shadow copy e ripristino
Data Destruction	T1485	Distruzione dati
Registry Run Keys	T1547.001	Persistenza mascherata
Service Stop	T1489	Terminazione servizi DB e mail
Application Layer Protocol — Tor	T1071	C2 via Tor hidden service

7.3 Locky.AZ

Locky (famiglia Locky/encoder) è un ransomware distribuito principalmente tramite allegati malevoli in campagne phishing. L'analisi ha evidenziato:

- rilevamento da 65 motori antivirus su 71

- il campione è una DLL (Alert.dll) eseguita tramite rundll32 e compressa con UPX (riferimento upx.sf.net nei memory pattern)

- nella sandbox la run è risultata sostanzialmente inerte: l'unico dominio contattato (tse1.mm.bing.net) è traffico benigno, nessun C2 reale osservato

- la classificazione come ransomware si basa sulle firme antivirus (Ransom:Win32/Locky) e sull'analisi statica, più che sul comportamento di rete osservato

Tecnica MITRE ATT&CK	ID	Descrizione
Command and Scripting Interpreter	T1059	Esecuzione tramite interprete comandi
Shared Modules — rundll32	T1129	Esecuzione DLL tramite rundll32.exe
Application Layer Protocol	T1071	C2 minimale (non osservato chiaramente)
Virtualization/Sandbox Evasion	T1497	Comportamento inerte in sandbox

8. Analisi tramite LLM

I risultati ottenuti da VirusTotal sono stati analizzati con il supporto di un Large Language Model. L'LLM si è dimostrato utile per sintetizzare rapidamente i report, confrontare i campioni e produrre una prima bozza della tabella IOC.

La valutazione della completezza e dell'accuratezza della risposta AI ha però evidenziato un limite significativo: nel triage iniziale erano stati classificati come IOC di rete alcuni domini in realtà benigni:

- api.msn.com e a-0003.dc-msedge.net — rilevati per WannaCry, sono telemetria di sistema Windows

- tse1.mm.bing.net — rilevato per Locky.AZ, è traffico di controllo revoca certificati

La verifica manuale dei tab Relations e Behavior su VirusTotal ha permesso di correggere l'errore, distinguendo il rumore della sandbox dai veri IOC — i domini DGA di CryptoLocker e l'hidden service Tor di WannaCry.



L'LLM è un valido acceleratore per il triage, ma le sue risposte richiedono sempre validazione manuale da parte dell'analista — in particolare nella distinzione tra indicatori malevoli e traffico legittimo di sistema.

9. Conclusioni

L'attività ha permesso di configurare correttamente un laboratorio di analisi malware isolato, comprendere il funzionamento della persistenza tramite Registro di Windows e analizzare tre campioni ransomware reali tramite VirusTotal, raccogliendo IOC di rete, indicatori di persistenza e comportamenti di sistema.

Attività	Strumento	Risultato
Configurazione laboratorio	FlareVM + VirtualBox	☑ Ambiente isolato — snapshot Clean_FlareVM
Raccolta campioni	malwareRepo.ps1	☑ 3 campioni ransomware selezionati
Calcolo hash SHA256	FlareVM tools	☑ Hash calcolati per tutti i campioni
Simulazione persistenza	Registro di Windows	☑ T1547.001 dimostrata — TestPersistence
Analisi VirusTotal	VT Detection/Relations/Behavior	☑ IOC raccolti per 3 campioni
Tabella IOC	Analisi manuale + LLM	☑ IOC verificati — rumore benigno escluso
Mapping MITRE ATT&CK	ATT&CK Framework	☑ TTP identificate per ciascun campione
Validazione LLM	Large Language Model	☑ Falsi positivi corretti con verifica manuale

La fase più rilevante dal punto di vista metodologico è stata la distinzione tra IOC reali e traffico benigno: i domini Microsoft inizialmente classificati come IOC dalla risposta LLM erano in realtà telemetria di sistema. Questo dimostra come la competenza dell'analista rimanga fondamentale anche in presenza di strumenti AI di supporto.

Lesson Learned

- L'isolamento di rete è condizione necessaria per l'analisi malware: anche un semplice campione ransomware può cifrare l'intera rete locale se eseguito in un ambiente non segregato. FlareVM e snapshot sono la prima linea di difesa del laboratorio.
- La chiave Run nel Registro (T1547.001) è la tecnica di persistenza più semplice e diffusa: è la prima cosa da controllare in un'analisi di Incident Response. Strumenti come Autoruns (Sysinternals) permettono di visualizzare tutti i punti di autorun del sistema in un'unica interfaccia.
- Gli hash SHA256 e gli IOC raccolti (domini DGA, IP C2, hash file) possono essere integrati in strumenti SIEM, EDR e threat intelligence platform per il rilevamento proattivo — questo è il valore operativo concreto di un'attività di malware analysis.

- ☑ Tutti gli obiettivi del laboratorio sono stati raggiunti. IOC raccolti e tabella MITRE ATT&CK completata per i tre campioni analizzati.